



MFA, сесије, сервиси и тајне

Вишефакторска аутентикација, животни циклус сесије и управљање тајнама

Континуирана провера идентитета

Ризик радње, трајање сесије, врста уређаја и промена привилегија одређују потребан ниво додатне потврде.

ПРЕДМЕТ АНАЛИЗЕ

Ризик који се анализира

Идентитет није трајно доказан једном пријавом. Ризик радње, трајање сесије, врста уређаја и промена привилегија утичу на то колико је додатна потврда потребна. Оперативна безбедност зато прати приступ и након почетне аутентикације.

ЗНАЧАЈ

Значај за безбедност система

Вишефакторска потврда и временски ограничене привилегије смањују последице украденог креденцијала. Управљање тајнама штити везе међу сервисима, где непажња често остане скривена јер нема корисничког екрана.

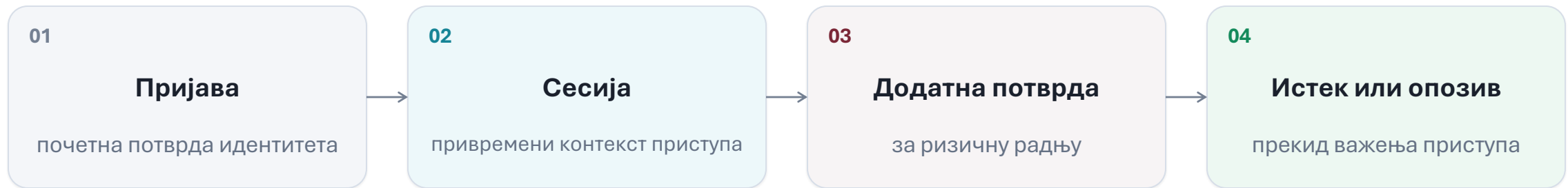
КРИТЕРИЈУМ ПРОВЕРЕ

Проверљив резултат

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

ОСНОВНИ ПОЈМОВИ

Пријава, сесија, додатна потврда и опозив описују животни циклус приступа.



ЗАКЉУЧАК

Поверење се не чува заувек. Систем га обнавља или опозива када се промени ризик.

Пријава

почетна потврда идентитета

01

Пријава потврђује идентитет у једном тренутку; не говори шта субјекат сме да ради касније.

Питање: који улаз покреће ову одлуку?

02

Вишефакторска потврда вреди за субјекта који ју је дао и за ограничено време.

Питање: која граница мора бити видљива?

03

Систем бележи време и начин потврде, али никада саму лозинку или код.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Шта ваш систем зна о кориснику одмах после пријаве, а шта тек треба да провери?

Сесија

привремени контекст приступа

01

Сесија је привремени доказ контекста, а не трајна потврда поверења.

Питање: који улаз покреће ову одлуку?

02

Сервер при сваком захтеву проверава да ли сесија и даље важи.

Питање: која граница мора бити видљива?

03

Запис о сесији чува када је настала, када је потврђена и када је престала да важи.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који податак о сесији сервер мора да провери пре сваке осетљиве радње?

Додатна потврда

за ризичну радњу

01

Додатну потврду тражи конкретна ризична радња, а не само тип корисника.

Питање: који улаз покреће ову одлуку?

02

Свака радња одређује колико стара потврда идентитета сме да буде.

Питање: која граница мора бити видљива?

03

Одлука бележи да ли је тражена нова потврда и из ког разлога.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Која радња у вашем систему заслужује додатну потврду и колико свежа она мора бити?

Истек или опозив

прекид важења приступа

01

Истек ограничава трајање поверења чак и када нема видљивог инцидента.

Питање: који улаз покреће ову одлуку?

02

Опозив има предност над сваким ранијим доказом идентитета.

Питање: која граница мора бити видљива?

03

Опозив и истек остављају траг: ко је прекинуо приступ, када и зашто.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА АНАЛИЗУ

Који догађај у вашем систему мора одмах да опозове постојећу сесију?

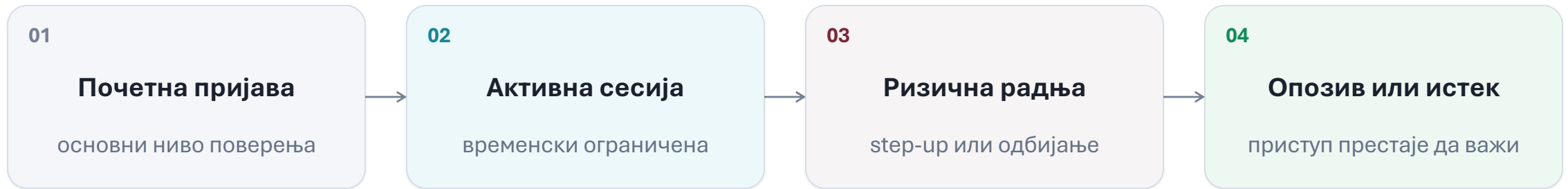
Различите врсте идентитета

Поређење приказује функцију сваког елемента и ограничење његове самосталне примене.

Идентитет	Намена	Посебан ризик
Људски корисник	Интерактивне радње и одговорност.	Крађа креденцијала или преширока улога.
Сервисни налог	Комуникација међу компонентама.	Тајна без рока или превелик опсег.
Привремени приступ	Кратка ризична интервенција.	Право остане активно након потребе.
Администраторски налог	Измене са великим утицајем.	Недостатак додатне потврде и аудита.

Модел животног циклуса поверења

Поверење се не чува заувек. Систем га обнавља или опозива када се промени ризик.



ЕЛЕМЕНТИ АНАЛИЗЕ

Анализа сваког корака обухвата покретача, место одлуке и траг који остаје после исхода.

Од тајне до безбедне употребе

Процес приказује улазе, место одлуке и доказ који остаје после исхода.

КОНТЕКСТ

Од тајне до безбедне употребе

Безбедно управљање тајном почиње пре њеног првог коришћења. Потребно је знати власника, сврху, компоненту која је користи и начин ротације. Сама вредност тајне треба да остане ван кода, екрана и записа који нису за то намењени.

01

Тајна се издаје само идентитету који јој је стварно потребан.

02

Систем прати истек и планира ротацију пре прекида рада.

03

Логови бележе употребу и неуспех без приказивања вредности тајне.

04

Опозив ограничава последицу сумње да је тајна компромитована.

Приступ има рок и контекст

Наведена правила остају видљива у имплементацији, тестовима и ревизији.

01

Сесија може изгубити важност пре планираног истека.

Јасно правило

02

Додатна потврда прати ризик радње, не само тип корисника.

Проверљива примена

03

Сервисни идентитет има мали, јасно оправдан опсег, као и људски идентитет.

Видљив доказ

Примена у развоју

Тим примењује тему кроз серверске провере, тестове и ревизионе записе током развоја.

РАЗВОЈНИ КОНТЕКСТ

Примена принципа у коду

Развојни тим унапред одређује које ситуације мењају ниво поверења: промена привилегије, приступ осетљивом податку или сумњива пријава. Тајне се референцирају из безбедног извора и никада се не преносе кроз код, тестне исписе или историју репозиторијума.

01

Дефинисана одлука и њена граница.

02

Серверска имплементација провере.

03

Позитиван и негативан доказ.

Случај: сесија после промене привилегије

Случај повезује опште правило са конкретним контекстом, серверском провером и очекиваним исходом.

СЦЕНАРИО

Пример: сесија после промене привилегије

Корисник се пријавио ујутру, а касније током дана добија виши ниво приступа. Ако систем не преиспита постојећу сесију, корисник може извршити ризичну радњу без додатне потврде која би била потребна да се пријављује у том тренутку. Обрнуто, одузета привилегија мора заиста да престане да важи, а не да чека крај дуготрајне сесије.

01

Сесија је привремени доказ контекста, не трајна потврда поверења.

02

Step-up аутентикација има смисла када се ризик радње промени, а не као произвољна препрека за све кориснике.

03

Сервисни налог добија исти третман као корисник: најмањи потребан опсег, рок важења и контролисану ротацију тајне.

Step-up не замењује проверу сесије

Додатна потврда идентитета вреди само уз важећу сесију и довољно свежу MFA потврду.

```
1 public StepUpDecision Evaluate(  
2     AuthSession session, RiskyOperation operation, DateTimeOffset now)  
3 {  
4     if (session.Revoked)  
5         return new(false, false, StepUpCodes.SessionRevoked, ...);  
6     if (session.MfaVerifiedAt is not { } verifiedAt)  
7         return new(false, true, StepUpCodes.MfaRequired, ...);  
8     if (!IsFresh(verifiedAt, operation.MaximumMfaAge, now))  
9         return new(false, true, StepUpCodes.MfaStale, ...);  
10    return new(true, false, StepUpCodes.StepUpSatisfied, ...);  
11 }
```

ТУМАЧЕЊЕ

Додатна потврда подиже ниво поверења само за ограничену радњу и кратак временски прозор.

БЕЗБЕДНОСНА ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Опозив има предност над старим доказом

Тест потврђује да опозвана сесија поништава и сасвим свежу MFA потврду.

```
1 [Test]
2 public void Evaluate_WhenSessionIsRevoked_DeniesWithoutOfferingMfa()
3 {
4     var decision = _policy.Evaluate(
5         Session(Now.AddMinutes(-1), revoked: true), Export, Now);
6
7     using (Assert.EnterMultipleScope())
8     {
9         Assert.That(decision.Allowed, Is.False);
10        Assert.That(decision.RequiresMfa, Is.False);
11        Assert.That(decision.Code, Is.EqualTo(StepUpCodes.SessionRevoked));
12    }
13 }
```

ДОКАЗ

Ни MFA потврда стара један минут не оживљава сесију која је опозвана.

ОЧЕКИВАНИ ИСХОД

Одлука одбија радњу и не нуди нову MFA потврду, јер сесија више не важи.

Садржај безбедносног записа

Запис садржи контекст потребан за реконструкцију одлуке, без тајни и непотребних личних података.

```
1 {  
2   "subject": "u-8",  
3   "action": "payment.approve",  
4   "sessionState": "revoked",  
5   "assurance": "mfa",  
6   "outcome": "denied",  
7   "secretValueLogged": false  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Честе грешке у имплементацији

Грешке настају када контекст, место одлуке или доказ остану нејасни.

01

Token третиран као вечна дозвола.

Нема јасног власника одлуке.

02

Администраторска права додељена без рока и прегледа.

Не постоји негативан сценарио.

03

Једна широка тајна дељена међу више независних сервиса.

Доказ не показује стварни исход.

Управљање тајнама у архитектури

Тајне имају власника, ограничен опсег, рок важења и поступак ротације.

ОБРАЗЛОЖЕЊЕ

Тајне као део архитектуре

Тајна није конфигурациона вредност као свака друга. Њено излагање може дати приступ без видљивог корисничког екрана, нарочито између сервиса. Зато развојни процес дефинише одакле тајна долази, ко је користи, када се ротира и како се проверава да није случајно завршила у репозиторијуму или логу.

01

Сваки сервисни идентитет има сврху и најмањи потребан опсег.

02

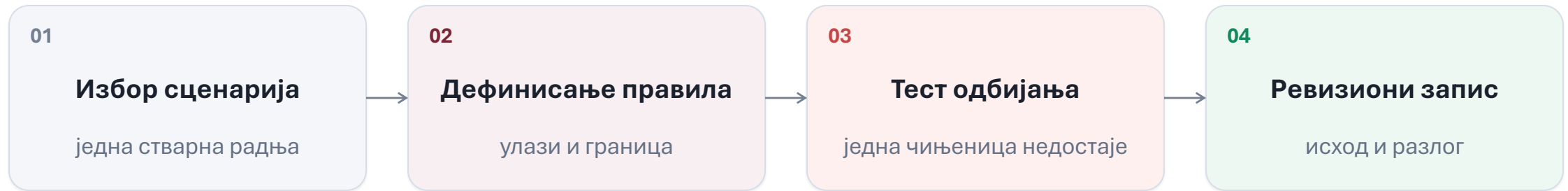
Ротација се планира пре истека, уместо да се чека прекид рада.

03

Тестови проверавају понашање при опозиву или истеку без приказивања стварних вредности тајне.

Примена на пројекат

Анализа једног сценарија обухвата одлуку, имплементацију, тест одбијања и доказ.

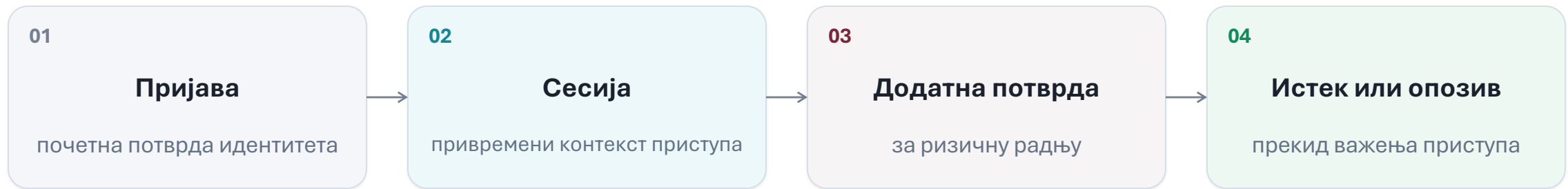


ПРИМЕНА НА ПРОЈЕКАТ

Пројектна примена теме „МФА, сесије, сервиси и тајне“ обухвата једну серверску одлуку, тест одбијања и доказ који други члан тима може да понови.

Провера разумевања

Разумевање теме подразумева објашњење одлуке и доказа независно од конкретног технолошког оквира.



ПИТАЊЕ ЗА ПРОВЕРУ

Која радња заслужује додатну потврду идентитета и који догађај би требало да опозове постојећу сесију?

Пројектна примена: применити исти модел на једну реалну границу у сопственом пројекту.